

Traccia

L'obiettivo di questo esercizio è quello di creare un errore di buffer overflow tramite un programma scritto in C.

Preparazione al test:

- Da terminale linux usiamo il comando `<cd /home/kali/Desktop>` per spostarci sul Desktop del sistema.
- Con il comando `<nano BOF.c>` creiamo (se non già presente) un file e lo modifichiamo andando ad inserire un codice in c che useremo per testare il buffer overflow

```
#include <stdio.h>

int main() {
    char buffer[10];

    printf("Nome utente: ");
    scanf("%s", buffer);

    printf("Nome utente inserito: %s\n", buffer);

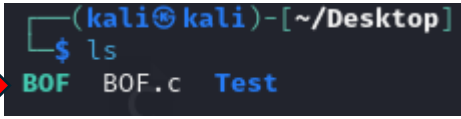
    return 0;
}
```

- Controlliamo se il file è stato effettivamente creato con il comando `<ls>`



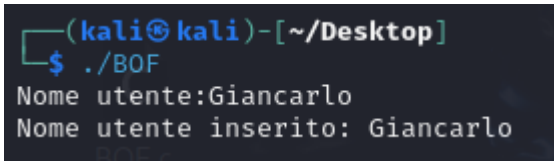
A terminal window showing the command `ls` being executed. The output shows two files: `BOF.c` and `Test`. A red arrow points to the `BOF.c` file in the output.

- Non ci resta che compilare il programma tramite l'istruzione `<gcc -g BOF.c -o BOF>` e controllare se è stato creato



A terminal window showing the command `gcc -g BOF.c -o BOF` being executed. The output shows three files: `BOF`, `BOF.c`, and `Test`. A red arrow points to the `BOF` file in the output.

- Mandiamo in esecuzione il programma e testiamo che funzioni correttamente



A terminal window showing the command `./BOF` being executed. The output shows the program running and displaying the prompt `Nome utente:` followed by the input `Giancarlo`, and then `Nome utente inserito: Giancarlo`.

Test con buffer da 10 caratteri

- Eseguiamo il programma e proviamo ad inserire più caratteri di quelli dichiarati nel buffer

```
(kali㉿kali)-[~/Desktop]
$ ./BOF
Nome utente: DavveroStaiLeggendo?
Nome utente inserito: DavveroStaiLeggendo?
zsh: segmentation fault ./BOF
```

Vediamo il messaggio di errore **segmentation fault**, ovvero un errore di buffer overflow.

Test con buffer da 30 caratteri

- Modifichiamo la grandezza del buffer all'interno del codice c

```
int main() {
    char buffer[30];
```

Salviamo e ricompiliamo il programma usando nuovamente l'istruzione
<gcc -g BOF.c -o BOF>

Fatto questo possiamo eseguire il programma modificato per ripetere il test precedente

```
(kali㉿kali)-[~/Desktop]
$ ./BOF
Nome utente: DavveroStaiLeggendo?
Nome utente inserito: DavveroStaiLeggendo?
```

Questa volta non c'è nessun messaggio di errore.
Se però proviamo a superare il nuovo limite l'errore tornerà.

```
(kali㉿kali)-[~/Desktop]
$ ./BOF
Nome utente: DavveroStaiLeggendo?NonHaiProprioNullaDaFare?
Nome utente inserito: DavveroStaiLeggendo?NonHaiProprioNullaDaFare?
zsh: segmentation fault ./BOF
```